Chapter 12 Securing Artificial Intelligence Systems in the Era of Large Language Models

Carmen-Gabriela Stefanita

IBM Security, Cambridge, MA, USA

12.1 The Need for an Artificial Intelligence Risk Management Framework in an Evolving Artificial Intelligence Landscape

Artificial intelligence (AI) systems can have profound impact on individuals, societies, and economies, so there is a need for safe AI development and use, following guidelines and regulations that prevent harm, discrimination, privacy violations, and other negative consequences.[1]

Many AI algorithms operate as "black boxes," making it difficult for humans to understand their decision-making process. AI systems can also inherit biases present in their training data leading to discriminatory out-

comes, thereby calling for strategies that can detect and mitigate bias, ensuring fairness and equal treatment of diverse groups.[2]

Given these concerns, it is essential for organizations to have an AI risk management framework and corporate policies to manage ethical, social, and cybersecurity challenges posed by the fast advancement and adoption of AI technologies.[3] This framework can be applied across enterprise solutions for various industry use cases that span on premise and software-as-a-service (SaaS) environments.[4] Nevertheless, we first need to understand the risks that require to be controlled before we attempt to manage them.

12.1.1 Threats of Cyberattacks Against AI Require Proactive Measures

You don't need to be a security practitioner to grasp and appreciate the risks associated with data breaches – confidential, private, or client data leaks. Many of us are also custodians of client data, requiring client information protection to maintain client trust. With the growing popularity of AI, specifically large language models (LLMs) and their ubiquitous use and fast adoption, risks have increased exponentially because AI is easily exposed to cyberattacks. While there are significant speed and productivity benefits of adopting AI at work and in people's private lives, they should not result in the loss of privacy, intellectual capital, or leak of differentiating information. If we are AI product developers, it is our responsibility to practice and codify the right set of standards by protecting the interests of clients and service providers who benefit from our AI applications. Here are some example topics of highest concern for organizations[5]:

- The top three barriers to AI adoption are: cybersecurity, privacy, and accuracy.
- Governments around the world are at various stages of assessing and developing strategies to understand, adopt, build industries around it, and regulate AI.
- Executives state that trusted secure ecosystem and network digital connections are the most important areas in which AI and machine

learning (ML) will enable greater transparency and visibility, as well as deliver faster results.

To develop the right framework for securing AI applications, we need to put ourselves in the attacker's shoes to see how they look to target each stage of the AI pipeline.[6] When building a new pipeline of AI technology, there is a data collection and handling phase where many people need access: data scientists, engineers, developers, etc. That sensitive data is a blinking red target that attackers are trying to get access to. Also, within the model development phase, there are new vulnerabilities that become new entry points that attackers will try to exploit. Open-source sharing repositories often lack comprehensive security controls, and they ultimately pass the risk onto the organization – and attackers are counting on it. Lastly, during inferencing in live use of AI applications, attackers can manipulate models, jailbreak guardrails, coax models into misbehaving by generating disallowed responses through the harming of the prompts. Let's have a closer look at these *security risks*, and the conditions under which they arise.

12.1.2 Security Risks Associated with Private, Public, or Hybrid Cloud Implementation

Security control is about risk management. Therefore, it is essential to start with an understanding of the risks associated with AI solutions. Risk varies based on the application of AI models and their implementation as a *private, public,* or *hybrid cloud* model. Examining the risks, key exposures, attack vectors, and defining specific controls will help improve the security and compliance posture. When implementing a framework for security of AI, it must be remembered that the operating model and the resulting security control measures will vary depending on the AI use cases to be managed. AI components such as AI models and training data are incremental add-ons to current existing application development and infrastructure deployment. We need to correctly identify where these models are embedded and how they are being used. AI subsystems leverage existing cloud, infrastructure, and application layers calling for unique controls for AI security risks due to AI solutions being hosted in

different cloud environments. Any AI risk government plan needs to support all the different use cases, platforms, and applications[7] (Figure 12.1).

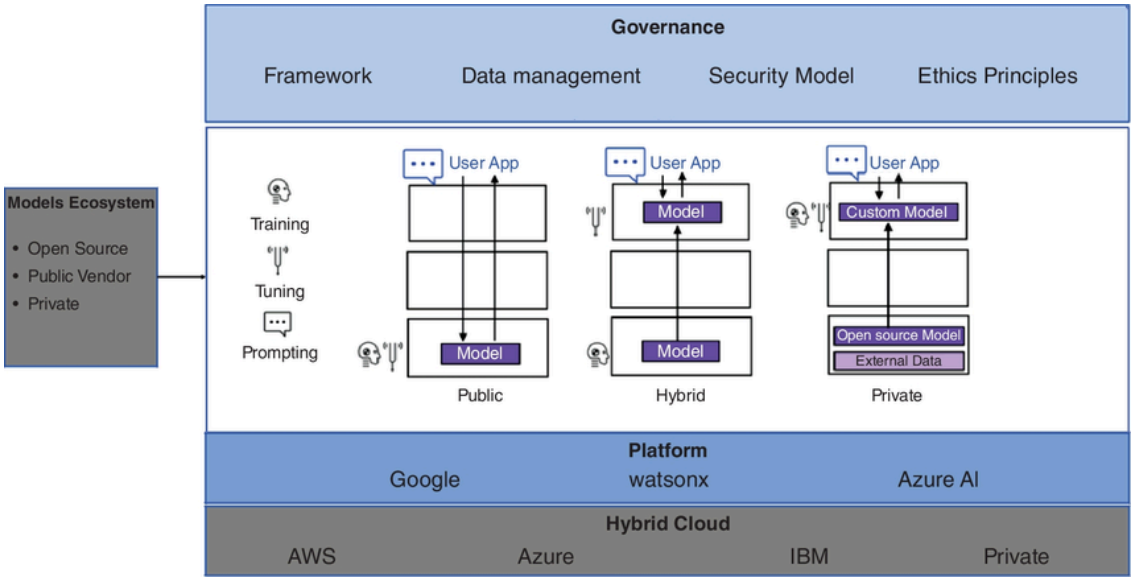


Figure 12.1 Use cases and implementation of influence security controls.

Here are the most common security risks depending on their implementation model:

Public Cloud

- Data Privacy and Compliance:
  - When storing sensitive data in a public cloud, there is the concern about data privacy and compliance with regulations (e.g. GDPR). This is because unauthorized access to cloud resources can result in data breaches.
- Data Transfer Security:
  - It is possible to intercept data sent to and from public cloud services if the data is not properly encrypted, posing a risk of data leakage.
- Shared Resources:
  - When public cloud environments are shared among multiple users, it can potentially lead to security vulnerabilities if resources are not properly isolated. A compromised neighboring resource could affect your AI solution.
- Identity and Access Management (IAM):
  - Misconfigured IAM policies can grant excessive permissions, leading to unauthorized access and data exposure.

- Vendor Lock-in:
  - Depending solely on a single public cloud provider can create vendor lock-in, making it challenging to migrate to another provider if needed.

Hybrid Cloud

- Integration Complexity:
  - Hybrid cloud environments involve both on-premises and public/private cloud components. Ensuring secure communication and data transfer between these environments can be complex.
- Consistency in Security Policies:
  - Maintaining consistent security policies across different cloud environments can be challenging and may result in security gaps.
- Data Residency and Compliance:
  - Managing data residency and compliance requirements across different environments is crucial to avoid legal and regulatory issues.
- Hybrid Identity Management:
  - Careful planning needs to be enforced when integrating identity and access management across hybrid environments to prevent unauthorized access.

Private Cloud

- Physical Security:
  - Private clouds offer more control over physical infrastructure, nevertheless they require robust physical security measures to prevent unauthorized access to servers and data centers.
- Maintenance and Patching:
  - Organizations need to be responsible for maintaining and patching the private cloud infrastructure, which can be a security risk if not done consistently and promptly.
- Insider Threats:
  - Organization employees use private cloud environments making them more susceptible to insider threats if proper access controls and monitoring are not in place.
- Resource Scalability:

- Scaling resources in a private cloud may be more limited compared to a public cloud, potentially affecting the AI solution's ability to handle varying workloads.

When designing and adopting AI systems hosted in cloud environments, organizations need to consider adopting comprehensive security practices that include implementing strong access controls, encryption, intrusion detection systems, regular security audits, and compliance monitoring, Additionally, it is recommended to stay informed about evolving security threats and best practices in cloud security, and to adapt organizational strategies accordingly.

12.1.3 Business, Legal and Cybersecurity Risks

AI is a technology, it is not inherently good or bad, it is about how we use it. It is essentially software. A recommendation system for credit determination, or for criminal sentencing are two AI examples that are very different in terms of their impact on society or the context around them; however, they rely on the same type of AI model. Therefore, how do we identify high vs. low-risk use cases, and why are these risks specifically security risks? To answer that, we need to look at the consequences of AI, how it is being used and what the implications are due to its use. This leads to a categorization of risk into three main classes:

- *Business:* Business risks include financial implications, reputational factors, and brand image risks.
- *Legal:* These risks are associated with lawfully permissible outcomes for an AI technology, as well as compliance risks.
- *IT Operations:* Risks of this nature arise from AI solution development and implementations manifested in its architecture and operations. The underlying technology used to implement various processes and business needs may not always be the best choice, and this can ultimately lead to security risks.

Organizations need to quantify these risks so that they can control them. The metrics used can be the outcome of the same type of algorithms organizations use in different contexts; therefore, it is the outcome they want

to control, not the algorithm itself. It is about getting that balance between identifying risks correctly, and applying *security controls* that have the highest impact for the riskiest situations.

The most frequently encountered risks in those three categories are captured in Table 12.1, together with some basic security controls.

TABLE 12.1

Most frequent AI risks by category and control.

Category	Risk	Control
Business	Bias and discrimination	Ensure correct representation of data categories.
	Trust and reputation	Consider how AI data is used in enterprise system dependencies. Add AI content to review processes. Include a safety system on top of the AI app to filter and monitor responses.
	Availability, performance, and costs	Map out infrastructure dependencies on systems using AI. Use backup and redundancy. Recovery preparedness plan should include AI dependencies.
Legal	Privacy and confidentiality	Legal disclaimers in privacy policies that mention Al should be used in products or processes. Interactive and explicit end user opt-out is necessary when using services that have embedded AI.
	Regulatory	Review and negotiate, whenever possible, third-party policies and terms of use. Check licensing of content for use produced by AI technologies.

Category	Risk	Control
	Copyright and ownership	Use solutions trained on curated or licensed content including the use of internally trained systems. Detect intellectual property misuse, or plagiarism. Trademark detection.
Cybersecurity	AI behavioral vulnerabilities	Models should have data input validation and output validation to catch problematic behavior.
	Threat actor evolution	Adjustment of social engineering training to consider targeted phishing and similar attacks.
	Enterprise, SaaS and third-party security	Filter, mask, or scrub sensitive content between organizations, APIs and chatbot Al services. Secure enterprise browser implementation.
	Insecure code generation	Create an AI staging ground to observe applications using AI models. Code review should include Al-generated code.
	Software security vulnerabilities	Model interactions with other systems should be analyzed to identify potential interactions. Use model output filtering to identify problematic outputs.

To make these security controls more impactful, organizations should consider these recommendations:

Business

- Leverage trusted AI after evaluating the vendor policies and practices:
  - Evaluate open-source trusted AI vendors while choosing models and training datasets.
  - Engage the procurement team to evaluate vendors' terms and match them to enterprise policy.
- Conduct threat modeling and secure coding practices for AI development lifecycle
  - Identify and incorporate the trusted supply chain sources AI modules, data, and open-source utilities into SBOM.
- Enable visibility, perform threat detection and response for AI applications and infrastructure.
  - Log activity at each layer and centralize in a security analytics platform for visibility.
  - Create AI systems-specific rules to detect exploits, anomalous activities and insider threats for potential model and data altering.
  - SBOM, ML models, and training data information should be cataloged and made available for the security operations team.
  - Build response playbooks and response automation to remediate any intrusion attempts or breach situations.

Legal

- Apply current privacy, security and compliance policies along with NIST AI risk management framework best practices as the base while AI regulations and policies are under formulation.
- Assess and decide AI maturity through the IBM AI framework.
  - Ensure transparency, explainability to prevent bias, hallucination, and poisoning.
  - Audit of the workflows, training data, and output should be conducted by independent team for accuracy and performance.
  - Service providers should create model awareness, benchmarking audit reports regularly to build trust.

- The data's origin and the data preparation process should be provided for trust and transparency.

Cybersecurity

- Leverage DevOps to automate application vulnerability scanning during the development lifecycle. It is also critical to implement data security at various levels (such as application and database) in line with the data classification analysis.
- Incorporate AI development, deployment, and use as part of security awareness and education.
- Enable secure access to users, models, and data:
  - Implement enterprise API key management to prevent AI systems breaches, hijacking and poisoning.
  - Monitor user-to-system and system-to-system access and privilege activity.
  - Design access control based on multimodels and training or through prompt bank per access control group.
  - Prevent access to unauthorized service providers, block transferring information to these vendors.
- Safeguard AI models, data, and infrastructure from adversarial attacks
  - Employ secure transmission methods across the supply chain, i.e. DevOps, data engineering, model training.
  - Protect internet and intranet boundaries to prevent unauthorized access and hijacking of AI models and data.
  - Strengthen the OS hygiene, controls of virtual machines, containers, and AI models to prevent exploitation.
  - Discover and fix cloud misconfigurations hosting data and models.
- Implement data privacy protection in the training, testing, and operations.
  - Manage data life cycle from sourcing trusted data, engineering, learning, and securely storing the multiple versions.
  - Scan data content for privacy information to avoid learning from that information.
  - Employ data loss prevention techniques to detect and prevent SPI, PII, and regulated data leakage through prompts and API's.

- Acknowledge risks on data accuracy, incorporate test and validation steps while using the output as part of task automation.

12.2 Security for AI Threat Model

An organization uses a structured approach to first identify security requirements and second, review security threats and potential vulnerabilities. They would then quantify the threat and vulnerability to prioritize remediation methods. Such an approach is known as a *threat model*[8] and it results in cataloging the threats, generating a profile of potential attackers and their methods. An AI security threat model (Figure 12.2) is based on a conventional threat model foundation with an added conventional threat management component. As LLMs incorporated into systems are being increasingly adopted across industries, organizations are confronted with new types of vulnerabilities and attack vectors,[9] so that conventional threats take on new meanings, adding a new component to the threat model. Additionally, the generative power of LLMs and their usage looks to change the entire cyber defense environment,[10] leading to a fourth component in the Threat Model, the new threat landscape.

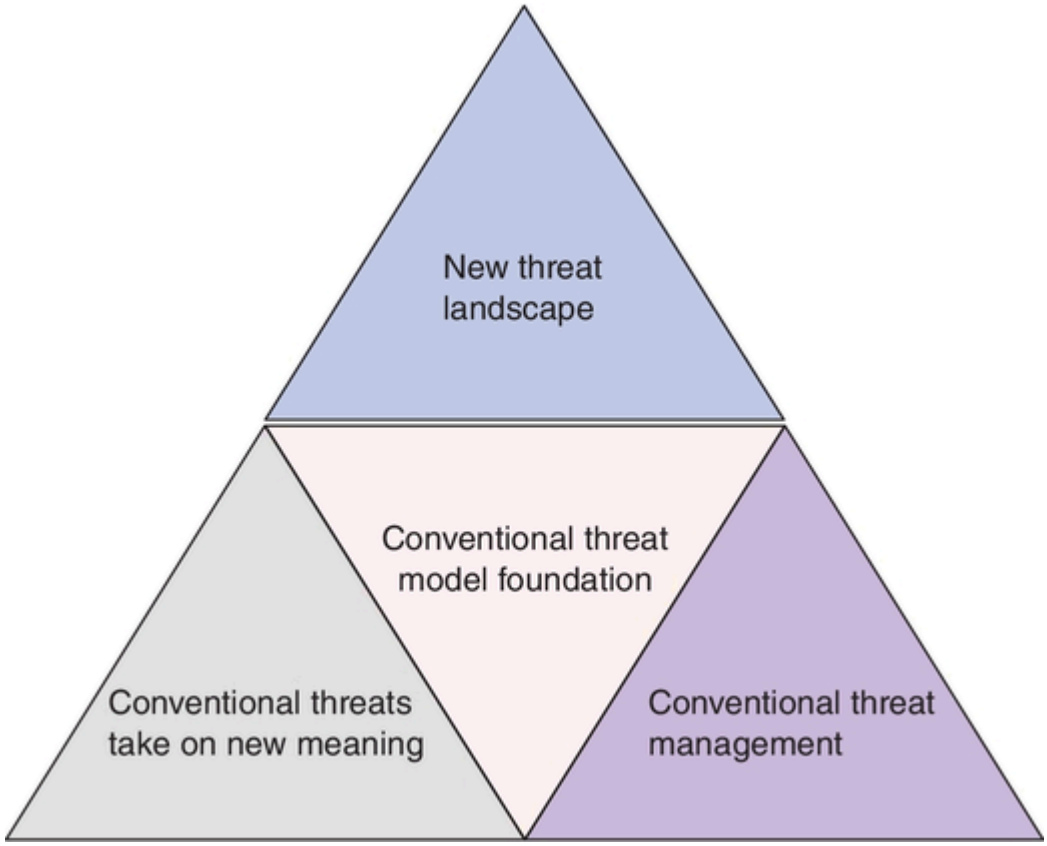


Figure 12.2 Security for AI threat model components.

12.2.1 Conventional Threat Model Foundation

Security controls need to integrate into operations and client offerings to protect applications from high-risk issues, even without embedding LLMs into systems. We cannot forget good practice, establishing comprehensive security protocols in the face of security threats and risks that have been around for a considerable time. Organizations have long adopted security risk frameworks to identify, assess, prioritize, and mitigate security risks across their information technology infrastructure and operations. Since traditional ML has already been incorporated into applications and businesses have been harnessing its potential, companies have turned to unified resources addressing well-known security concerns. There are a few industry frameworks such as MITRE Atlas[11] that are a guidance for adversarial attacks because they contain a highly detailed and cross-referenced repository of information about real-world adversary groups and their attack tactics and techniques. For instance, there are four ways identified by MITRE under which an attacker can gain initial access: ML supply chain compromise, abuse credentials of existing accounts, evade an ML model, and exploit public-facing applications. Although not a threat model per se, many organizations rely on it because they use the

tactics and techniques to develop a Threat Model of their own. More traditional threat model approaches are covered by PASTA (Process for Attack Simulation and Threat Analysis),[12] STRIDE (Spoofing Identity, Tampering with data, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege),[13] or OCTAVE (Operationally Critical Threat, Asset, and Vulnerability Evaluation).[14] Also, the well-known NIST cybersecurity framework[15] published by the US National Institute of Standards and Technology and based on existing standards, guidelines and practices is often used by organizations for information on compliance and policies. Organizations need to consider these security frameworks as guidelines that provide a systematic methodology for understanding and categorizing potential threats and vulnerabilities, evaluating their potential impact and likelihood, stay compliant, and then making informed decisions on risk mitigation strategies.

12.2.2 Conventional Threat Management

A holistic and agnostic approach should be adopted while building AI solutions like any other application development and infrastructure deployment. For example, an *initial access* threat defined in the MITRE Atlas framework and mentioned above can be prevented by applying some of these techniques: *verifying ML artifacts, multifactor authentication (MFA), model gardening* and *addressing weaknesses in an internet-facing computer or program*. Additionally, recommendations for conventional threat management require a multidimensional approach covering data, application, network, and identity security. It is best to use the "Zero Trust Principles" while securing AI.[16]

The following points describe some conventional threat management recommendations applied to AI applications:

Business Recommendations

- Request approval using a governance process that identifies the business need, owners, impact, and defined business outcome the AI module will achieve.
- Ensure transparency and explainability to prevent unintended bias.

Legal Recommendations

- Implement privacy protection and security measures in the training and testing data phases.
- Perform security audits and establish incident response for AI systems.

Cybersecurity Recommendations

- Integrate security practices and testing throughout CI/CD AI development life cycle[17] and following deployment.
- Safeguard deployed models and infrastructure from malicious attacks.
- Conduct threat modeling and implement secure coding practices.

Threat management typically includes processes for risk assessment, risk management, risk monitoring, and incident response, enabling organizations to proactively address security threats, protect sensitive data, and ensure the resilience of their systems and operations in an ever-evolving threat landscape.

12.2.3 Conventional Threats Take on New Meanings

When AI is embedded into applications, there are some additional dimensions that conventional threat management needs to be supplemented with:

Bias[18]

An AI system reputation is based on the accuracy of its results. Skewed results due to bias will harm the confidence of the application. The model's responses would be biased and discriminating if the data is biased, i.e. training data that is used to develop the model is not representative of the population. Hence:

- It is necessary to reduce bias as much as possible in the data collection phase.
- Data from trusted sources should be recorded and leveraged after being verified and audited by the development team involving manual

assessments, automated tools, and human reviewers.
- Bias handling mechanisms should be used to handle data bias along with other biases in the AI system, data augmentation for sampling bias, and regularization for prejudice bias. It is necessary to perform adversarial training and an analysis of causal effects of sensitive attributes on decision-making for algorithmic bias, and debiasing algorithms for label bias.

Trust and Reputation[19]

AI models are often considered a "black box" due to a lack of technical AI awareness. Because of incorrect responses, lack of model architecture transparency, and other reasons stakeholders cannot trust the deployed AI models. Some recommendations that can be made:

- Service providers should create model awareness by creating enough documentation, benchmarking the models, and generating metrics and audit reports regularly to build the trust of the customers/clients.
- Vendors and service providers should provide full transparency to clients with explainable models and options for the client to reconfigure the models based on context.
- The data's origin and the data preparation process should be provided for trust and transparency. The output should be based on content and context accuracy and confidence rating.

Performance

It is likely that the AI model suddenly or gradually starts to provide predictions with lower accuracy compared to its performance during the training period. Concept drift happens when the definition of what we are trying to predict changes, so our algorithm provides inaccurate predictions. These could be gradual, sudden, or recurring. Data drift occurs when the statistical properties of the training/input data change.

- Drift should be established by using a statistical mean and standard deviation.
- Processes should be in place for monitoring model metrics, model analysis, and drift detection. When drift is detected, then prepare data

for retraining.
- Incorporate continuous learning for ML systems based on end-user feedback. To check the accuracy, start with daily manual audits and subsequently find automation processes.

Standard correction mechanisms help maintain good quality and relevant models. They correct data labels by computing the latest validated ground truths to maintain data integrity and relevancy.

Compliance and Consent

AI models are dependent on the data. With new models in the market, and large data collection initiatives, new vulnerabilities are uncovered in AI applications. For instance, third-party vendors collect, utilize, share, and sell data more often than in previous years. This means that service providers and enterprises must be up to date with new compliance risks of handling sensitive information and take additional precautions to mitigate these risks such as:

- Agreements with data vendors should disclose ownership, usages, accuracy, sale of proprietary data and the right of removal.
- Guidance to use SPI, PII, trademarks, and patented information should be documented. AI models, training data, and vendors should be part of the software bill of material.

People and Culture

AI will be incorporated successfully only if people, culture, processes, and tools are enhanced to adopt nuances brought forward by AI systems.

- Secure by design concepts should be adopted by developers to identify the gaps during the early part of the lifecycle so that they can be remediated before deploying a vulnerable model and application.
- Adhering to strict hygiene and careful use of cloud configuration, CI/CD pipeline, and ML operations will help the team avoid breaches, misuse of AI, and data exposures.
- Cultural awareness training should be made available to identify the advantages of AI and the safeguards taken to prevent adverse intent.

12.2.4 New Threat Landscape: Generative AI Specific Risks

In the past, many new cyber threats were met with individual point solutions; however, the emergence of LLMs looks to change the entire cyber defense landscape. Business leaders are looking to generative AI to increase their return on investment. By becoming widely popular, it has added new risks through its adoption by organizations:

Privacy and Confidentiality

- Generative AI applications could exacerbate data and privacy risks. They use a massive amount of data and create even more new data, which are vulnerable to bias, poor quality, unauthorized access, and loss.
- Accidental SPI and PII leakage can occur as part of the prompts, violating corporate and regulatory policies and severely impacting corporate Security posture.

Hallucinations

- Data and model inappropriate retention impedes traceability of fault, accuracy, or hallucination.

Poisoning

- Adversaries, government, and non-government entities will use data poisoning methods to influence AI to paint false narratives. They will publish fake content, context, and statistics from public sources. The fake data strives to bias or “poison” the data to compromise the resulting ML model’s accuracy.
- Political Polarization: LLMs have a strong grasp of natural communication. They can generate human-like communications in a wide variety of scenarios and reason about a wide range of topics; therefore, they can be manipulated.

Social Engineering

- Fraudsters have already leveraged AI to duplicate voice of C-level execs to successfully request wire transfers.
- Blackmail may also increase with the continued evolution of deep fake technologies.

Kernel Rootkits and Code Signing Abuse

- AI and GAN will allow attackers to code complex kernel rootkits to bypass new kernel protections.

Implementing security controls, as well as having regular security assessments and audits are critical measures needed for identifying and mitigating vulnerabilities in AI systems.

12.3 Implementing a Security for AI Framework

In our practice, we have adopted a high-level framework that covers best practices for securing AI applications, and we recommend organizations develop one of their own. Our approach is based on the earlier mentioned security threat modeling that is well known to cybersecurity practitioners. Such a framework for securing AI can be boiled down to a few principles: *Secure the data, secure the model, secure usage*. In addition, we need to *secure the infrastructure* on which the models are being built and run. We start by identifying the risks, the threats and then map them to our AI use cases by considering regulations. In doing so, we end up with a *matrix of security controls*.

12.3.1 Matrix of Security Controls

To define a *matrix of security* controls, we start by applying the learnings from secure application development also known as *DevSecOps*. We are already familiar with *DevOps*, the application building process that contains the different phases of *design*, *develop/build*, *test*, *deploy*, and *manage*. When we add security *Sec* into *DevOps*, we have secured each of those elements by adding controls to every stage in the application lifecycle. Figure 12.3 shows an example *matrix of security controls* to secure application development.

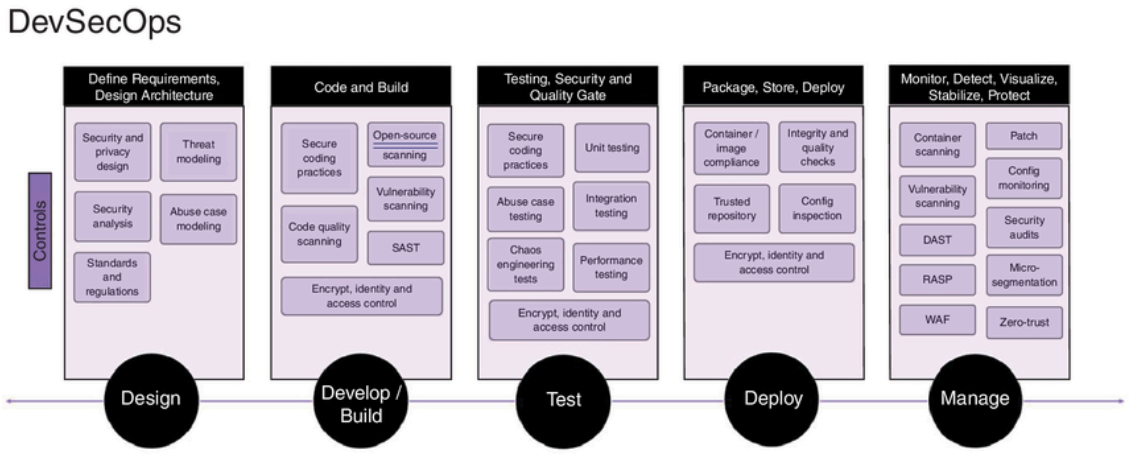


Figure 12.3 Example matrix of security controls for secure application development.

When data scientists build *traditional ML models*, they follow the same application development process that is called *MLOps*. They apply that pattern to *MLOps* where the application is a set of components secured by adding controls at every development stage. This means, data scientists need to understand where risks come from during the lifecycle of data and lifecycle of the model, and what security controls they can potentially apply to keep a balance. Figure 12.4 looks at the top attack vectors and techniques for defensive approaches when bringing in traditional ML models and data together.

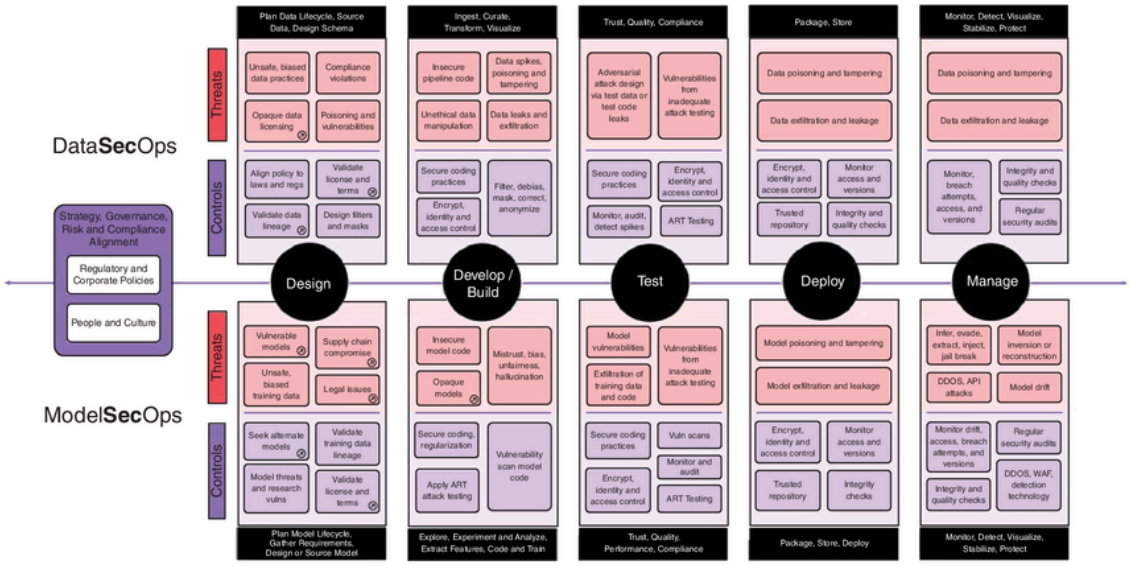


Figure 12.4 MLSecOps containing both data and model security controls.

In this high-level view, the threats and controls are summarized at every stage of ML design, develop/build, test, deploy and manage, just like in the *DevOps* lifecycle, paired with the different tasks performed during these phases. It shows threats staged in the data operations (*DataOps*) lifecycle, in the model operations (*ModelOps*) lifecycle, and the complementary

controls that account for those threats. For instance, looking at the lifecycle of data, it emphasizes where the data is obtained from, what the schema is going to look like, how the data is ingested, how the transfer of the data is occurring, how features are engineered and used for training and model hyperparameter optimization. Similarly, on the *ModelOps* side, different models are explored, training code is created, and jobs scheduled, followed by testing, deploying, and managing. This view shows the controls needed to be implemented at every stage. Clicking on each of these phases would ideally give a deep dive into what the threats and controls are. Remember the types of risks, then map each task within this data lifecycle to the *AI threat model*, then choose from a list of appropriate controls. This is how we build a *matrix of security controls*.

12.3.2 Enforcement of Security Controls

AI risk management uses a tool-based approach to measure the effectiveness of the implemented controls. The output metrics determine the level of success for a control. Figure 12.5 shows some example tools used at the different stages of *DataOps*. For instance, Watson Knowledge Catalog[20] can be used for certain data controls, or an open-source tool provided by Deepchecks[21] for a few deep dives into data such as feature-feature correlation or other types of data control.

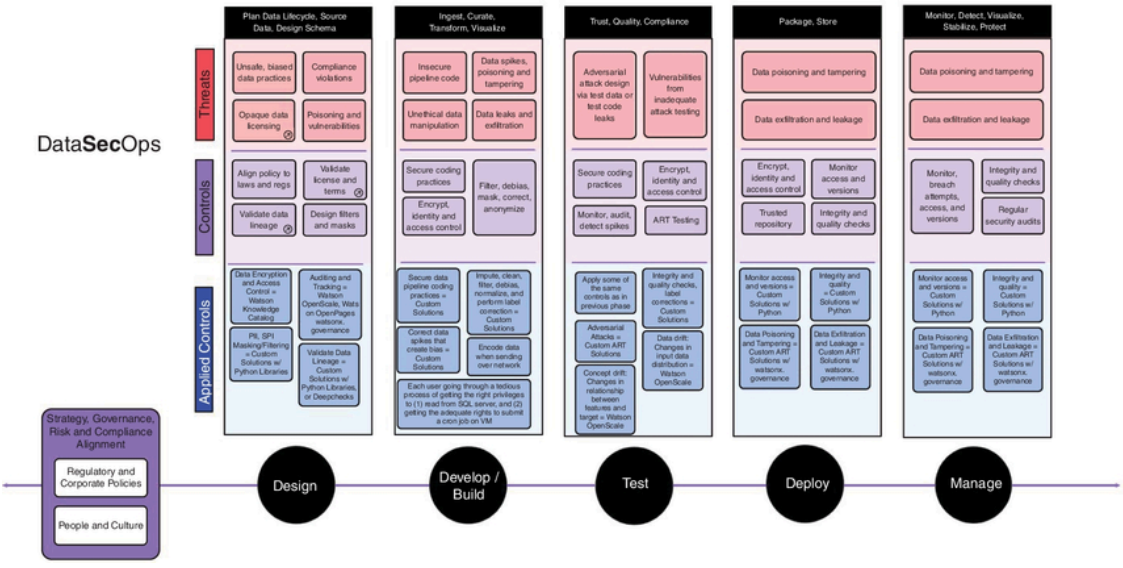


Figure 12.5 Enforcing DataSecOps.

On the *ModelOps* side, there are a variety of control options available, for example, for drift and explainability such as through *OpenScale* and

OpenPages in watsonx.governance[22] (Figure 12.6). LLM drift can be detected by using metrics such as ROUGE[23] or BLEU, where ROUGE stands for recall-oriented understudy for Gisting evaluation, and BLEU stands for bilingual evaluation understudy.[24] Both are metrics for evaluating the quality of automatic text summaries by comparing them to human-generated summaries. They were initially developed for natural language processing and extended to LLMs. There are also *Model Cards*[25] and *AI Factsheets*,[26] tools that enhance transparency and provide information about AI models, both serving slightly different purposes. Model cards provide detailed technical information by focusing on the model itself, its development, performance, and potential ethical considerations. Model cards are typically targeted at developers, researchers, and users of the AI model. AI factsheets, on the other hand, are designed to provide high-level, standardized information about a class of AI models such as classification models, and not just a single model. They are intended for a broader audience, including regulators.

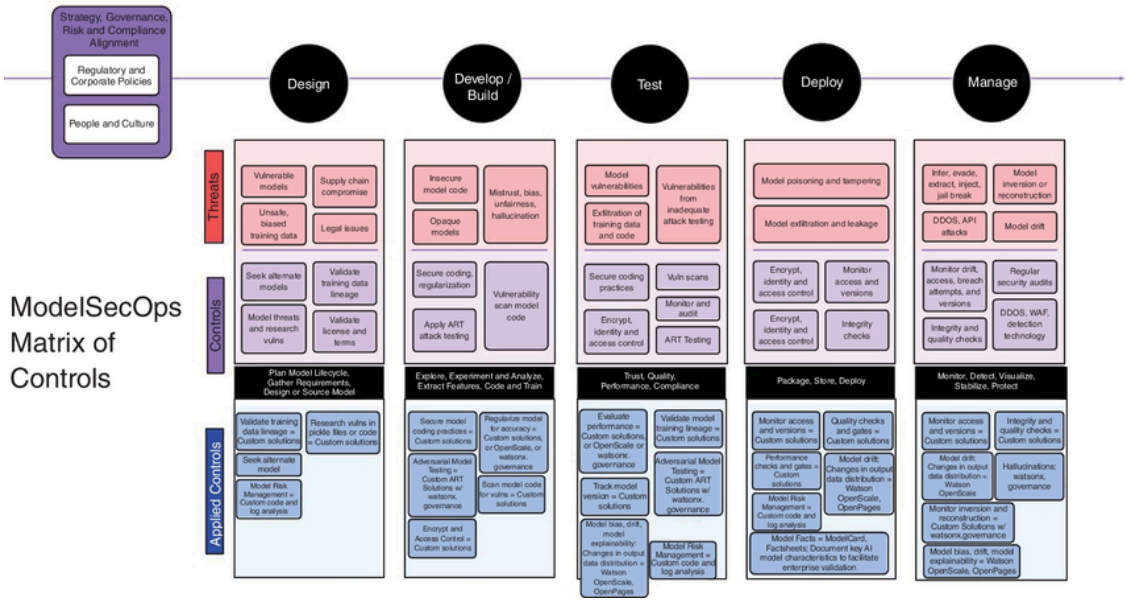


Figure 12.6 Enforcing ModelSecOps.

12.3.3 Security Controls Extended to LLMs

In order to better understand the origins of risks and threats of AI, and what controls to apply, the best vantage point is the one of the AI software developer. There is a *traditional school of thought* around traditional ML where the data is somewhat fixed with some relatively minor data transformations as reflected in *DataOps*, and where more attention is given to

the model that is being built. This is *model-centric AI* or *data-driven AI* (Figure 12.7). It is reflected in the *Dev + MLOps* lifecycle to which security controls are applied. And then, there is an *emerging school of thought* known as *Data-Centric AI*[27] due to the big paradigm shift in AI development that brought about Generative AI or LLMs. Here, a lot of emphasis is put on the data, and the model is somewhat fixed. Both approaches are more from the data science vantage point which also intersects security. That is because to understand how to control the risks and threats, we need to understand the "what" from a data science perspective. The question becomes: What is that "what" for *Data-centric AI*? Is it *Dev + LLMOps*[28]? Or is it shifted more toward *Dev + DataOps* which is part of *LLMOps*? Where does this leave one with the AI risk management framework that was centered around traditional ML and controls for *Dev* and *MLOps*? LLMOps is a new term, already in use by the data science community. It stands for large language model operations (Operationalizing LLMs).

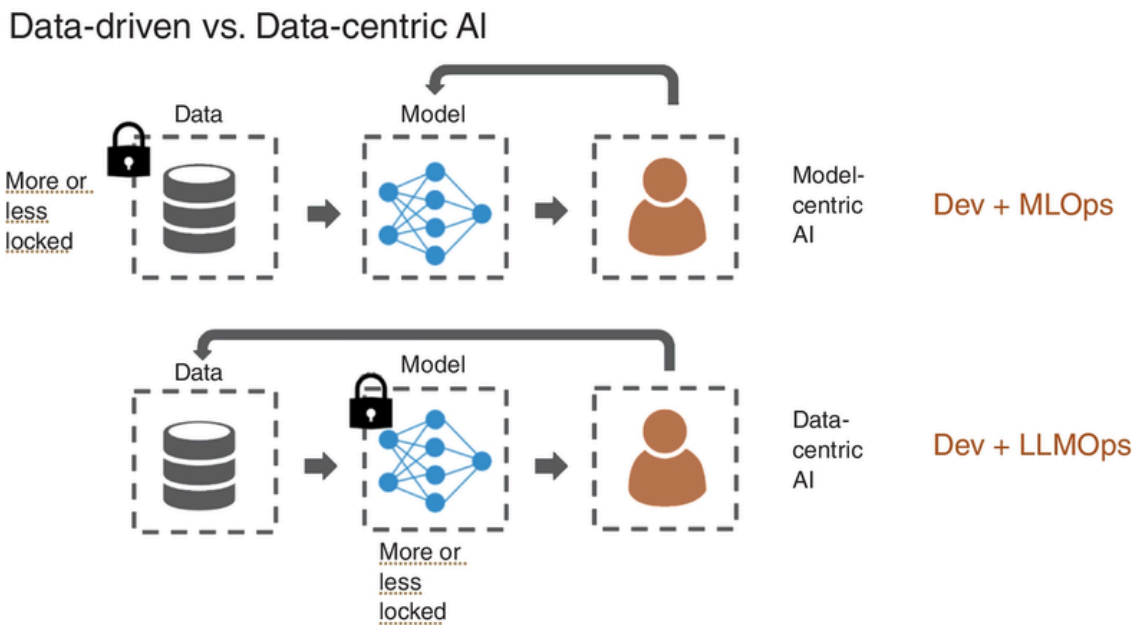


Figure 12.7 Schools of thought around AI.

The AI consumption model considered earlier helps with the understanding of the AI risk management framework for LLMs, as shown in Figure 12.8 which may not encompass all possible scenarios. At a high level, there are consumer LLMs used by individuals for personal reasons. There are employee LLMs internal to an organization serving corporate data and answering corporate questions. Then, there are customer LLMs when

a company produces a feature, a product, or a service that customers consume.

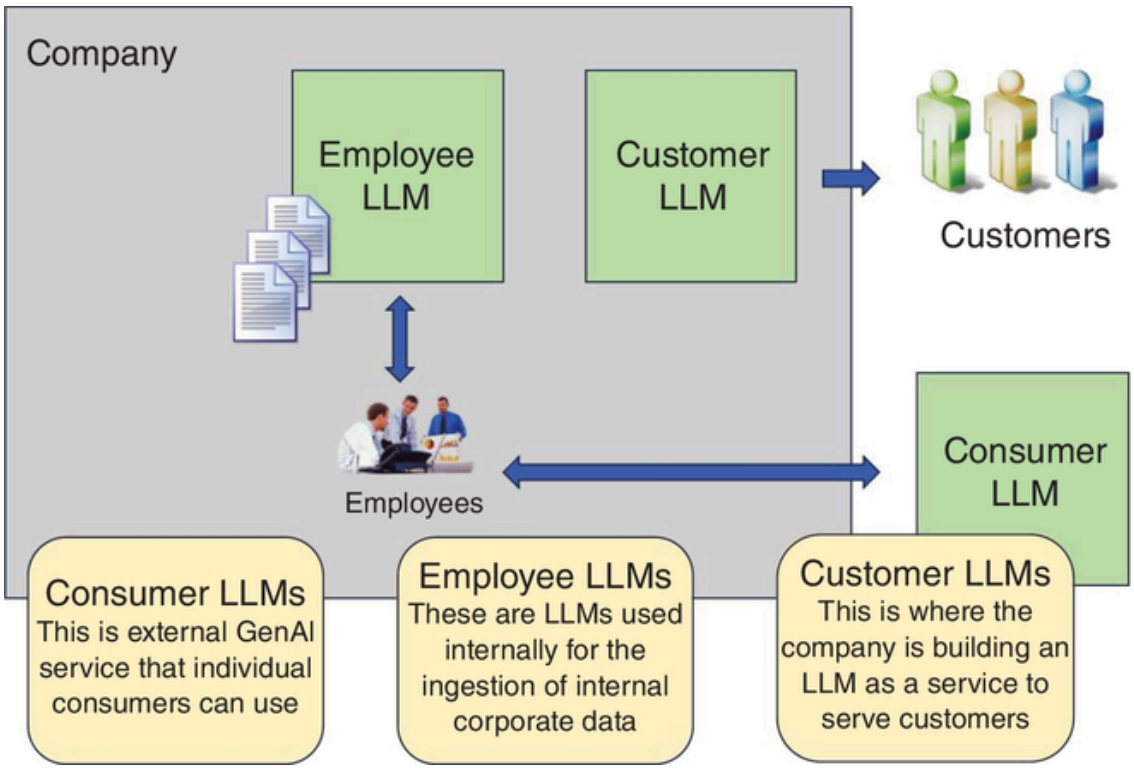


Figure 12.8 LLM use in organizations.

Figure 12.9 is a simplified architecture of *LLMOps* during the *deployment* phase showing what we need to consider for controls.

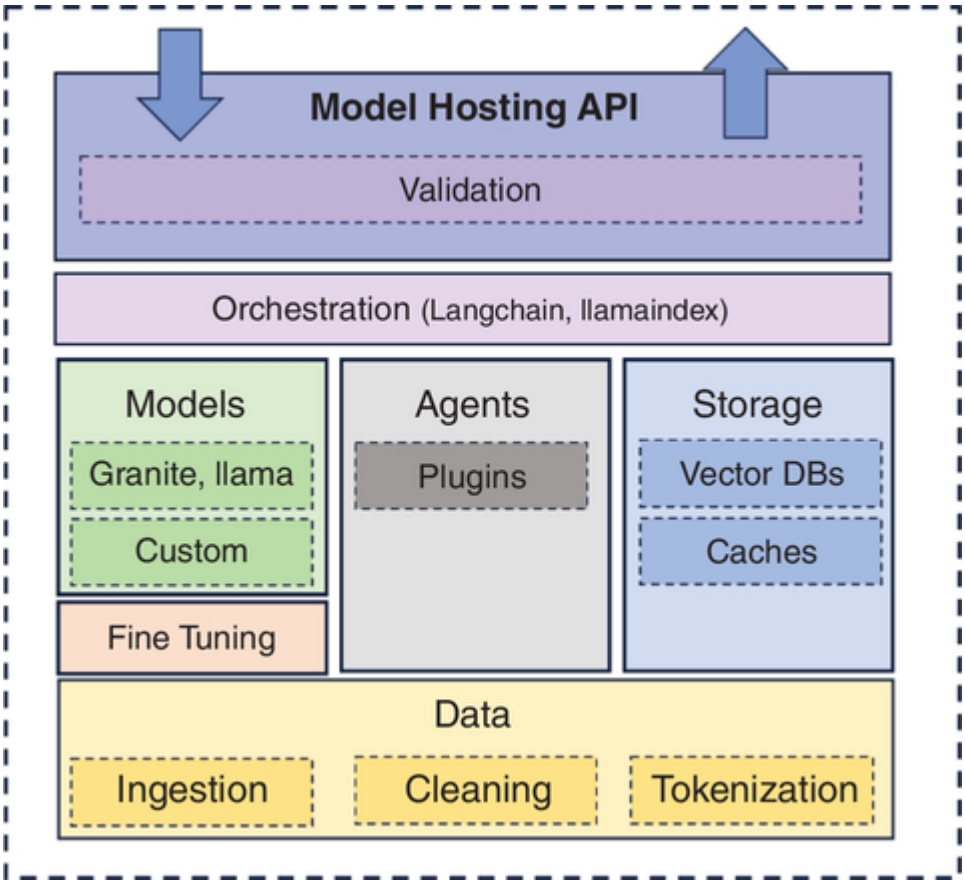


Figure 12.9 LLMOps during deployment phase.

A question is coming in as a *prompt* and going to a *validation layer* where only a particular kind of question gets answered. Some common technologies and security controls exist in this validation layer, such as *guardrails*. Prompts need to be stored so that production prompts can be swapped out or iterated on. A technique called *prompt engineering*[29] is used to communicate to an LLM and receive from an LLM contextual information. *Prompt templates* exist, consisting of texts placed right before a user's prompt to standardize the output format and quality, creating a scalable and reproducible way to generate prompts. They can contain instructions to an LLM, few-shot examples, or different chains of actions to be executed. For instance, based on user feedback, it may be advisable to conduct some A/B testing with different prompt templates, and track the performance of each prompt in real time. There are also several tools available to process data and "tweak" the LLM to ensure that it can deliver optimal responses within the desired business context. Some popular tools are *LLM Agents*. These tools assist users in generating responses quickly by creating a sequence of related prompts and answers in a logical order. LLM Agents leverage the power of LLMs to determine which actions to take based on the user's initial prompt. Agents combine LLMs

with prompt templates to create a series of prompt-response pairs to provide the user with a final answer.

Once a prompt passes through validation, there is an *orchestration layer*. The orchestration layer basically serves the function of "what do I do with it?" This can be handled by prominent LLM agents like *Langchain*[30] or *LlamaIndex*.[31] The system can take a question, move it into a storage layer to cache it, checking whether there are other similar questions to base off it. Then, the question is going back up to the orchestration layer. From there, it will go to a model, and that model will send the answer back up to the user. Or, in an enterprise instance, if there is a custom enterprise model, the orchestration layer might identify that the question is going to be about enterprise data. Therefore, it will pass it to a vector database, which then matches it to corporate internal data. The data is taken and passed to an LLM for summarization, and then passed back up. At that orchestration layer, there is a balance between calling a model, calling agents, or calling storage. All three scenarios may happen in a single request made through a prompt.

At a lower level, there is data for which tools are now being developed to perform *LLM Observability* to make sure that all the prompt templates, prompts, and responses are monitored in real-time, so that *prompt engineers* can understand and find the root cause of any negative feedback and improve the prompts. An LLM Observability system should collect data in the form of strings of prompt/response pairs.

Embeddings are part of LLM Observability, and are internal, latent representations of information. A model uses those to make sense of the data. Embeddings can be generated using an embedding generator model (e.g. GPT-J or BERT), and then monitored in real time for any change in behavior or negative feedback from users. Problems in responses could be found by clustering prompts and responses, then finding problem clusters by looking at evaluation metrics per cluster, drift per cluster, or user feedback per cluster. Problems can then be fixed through iterative workflows involving prompt engineering or fine tuning.

Following the same five phases of AI software application development, a Matrix of Security Controls for LLMs can be built by identifying risks and

threats within each stage as they pertain to DataOps (secure data), ModelOps (secure model), and secure usage. All of this is in view of the data-centric AI approach, where attention to security controls shifts more on data (DataOps) and AI usage. The matrix is then implemented into the framework to secure the data, secure the model, secure usage, and infrastructure. Next, we check if the outcome of those controls is compliant with regulations. Lastly, we continue iterating on this process of constant aligning with our governance objectives until we minimize security risks. *This is how you implement an AI risk management framework*.

12.4 Conclusion

The rapidly evolving nature of AI demands constant watchfulness. As AI technologies become increasingly integrated into business applications, their vulnerabilities become more apparent, necessitating planned, robust measures to protect against potential threats. Furthermore, threat landscapes keep changing, while new vulnerabilities emerge regularly. It is critical to ensure transparency in AI development and accountability for the actions of AI systems in an organized way. AI developers must have an AI risk management framework for providing transparency about how AI systems make decisions; however, securing AI is not the sole responsibility of one team, entity, or sector. It requires collaboration among different business units, as well as governments, industry leaders, researchers, and the public. It is important to ensure that we govern AI technologies so they are used for the benefit of society and do not harm individuals or groups. It is exciting to know that AI-powered security measures can enhance our ability to detect and respond to threats more effectively, and that AI can be used to develop adaptive defenses that learn and evolve to protect against new and emerging risks. AI is an international collaborative effort, essential in addressing global AI security challenges in a coordinated manner for responding to cyber threats.

Acknowledgments

This work would not have been possible without the collaborative involvement from Srinivas Tummalapenta, Sridhar Muppidi, Kaleb Walton,

and Ryan Dougherty who lent their valuable cybersecurity expertise to various topics discussed here.

Notes

1. G7 Code of Conduct “Hiroshima Process International Code of Conduct for Organizations Developing Advanced AI Systems” (2023) available online https://dd80b675424c132b90b3-e48385e382d2e5d17821a5e1d8e4c86b.ssl.cf1.rackcdn.com/external/hiroshimaprocessinternationalcodeofconductm8ct-fcuob4umdz3uob5zquct6fe99641.pdf
2. EU Artificial Intelligence Act (2023) available online https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:52021PC0206
3. White House Executive Order (Oct 2023) available online https://insidecybersecurity.com/sites/insidecybersecurity.com/files/documents/2023/oct/cs2023_0236.pdf
4. IBM Principles for Trust and Transparency (2023) available online https://www.ibm.com/policy/trust-transparency-new/
5. Gartner Top 10 Strategic Technology Trends for 2024 (2024) available online https://www.gartner.com/en/articles/gartner-top-10-strategic-technology-trends-for-2024
6. NIST “Trustworthy & Responsible AI Resource Center” (2024) available online https://airc.nist.gov/AI_RMF_Knowledge_Base/Crosswalks
7. IBM WatsonX online documentation https://dataplatform.cloud.ibm.com/docs/content/wsj/analyze-data/xgov-overview.html?context=wx&audience=wdp
8. NIST AI RMF Playbook (2023) available online https://airc.nist.gov/AI_RMF_Knowledge_Base/Playbook
9. IBM Statement on the Landmark EU AI Act (2023) available online https://newsroom.ibm.com/IBM-Statement-on-the-Landmark-EU-AI-Act
10. IBM “AI will change the world – the terms are up to us” (2023) available online https://www.ibm.com/blog/b7-eu-ai-act/
11. MITRE Atlas (2023) available online https://atlas.mitre.org/
12. Cybersecurity Exchange (2023) available online https://www.eccouncil.org/cybersecurity-exchange/
13. Microsoft (2023) available online https://learn.microsoft.com/en-us/previous-versions/commerce-server/ee823878(v=cs.20)?

redirectedfrom=MSDN

114 Carnegie Mellon University (2023) available online https://insights.-sei.cmu.edu/library/operationally-critical-threat-asset-and-vulnerability-evaluation-octave-framework-version-10/

115 NIST Cyberframework (2023) available online https://www.nist.gov/cyberframework

116 Scott W. Rose et al. “Zero Trust Architecture” NIST Publications (Aug 2020) available online https://www.nist.gov/publications/zero-trust-architecture

117 Monika Steidl et al. “The Pipeline for the continuous development of artificial intelligence models – Current state of research and practice” J. Systems and Software, vol 199, May 2023, p. 111615 https://doi.org/10.1016/j.jss.2023.111615, available online Desai https://www.sciencedirect.com/science/article/pii/S0164121223000109

118 Meredith Broussard “Bias in Artificial Intelligence” Harvard Magazine blog 8.2.21 available online https://www.harvardmagazine.com/2021/08/meredith-broussard-ai-bias-documentary

119 Adib Habbal et al. “Artificial Intelligence Trust, Risk and Security Management (AI TRiSM): Frameworks, applications, challenges and future research directions” ScienceDirect Expert Systems with Applications, Vol. 240, 15 Apr 2024, p. 122442 available online https://www.sciencedirect.com/science/article/abs/pii/S0957417423029445

220 IBM Watson Knowledge Catalog online documentation https://www.ib-m.com/products/knowledge-catalog

221 Deepchecks site https://deepchecks.com/

222 “Comparing IBM Watson OpenScale to open source on AI explainability” (2023) available online https://www.ibm.com/blog/comparing-ibm-watson-openscale-to-open-source-on-ai-explainability/

223 “An Intro to ROUGE, and how to use it to evaluate summaries” FreeCodeCamp tutorial available online https://www.freecodecam-p.org/news/what-is-rouge-and-how-it-works-for-evaluation-of-sum-maries-e059fb8ac840/

224 Renu Khandelwal “BLEU – Bilingual Evaluation Understudy” Towards Data Science (Jan 25, 2020) available online https://towardsdata-science.com/bleu-bilingual-evaluation-understudy-2b4eab9bcfd1

25 Anokhy Desai “Five Things to Know about AI Model Cards” online blog Aug 23, 2023 https://iapp.org/news/a/5-things-to-know-about-ai-model-cards/

26 “IBM AI Factsheets further advances trust in AI” IBM Research blog 9 Jul 2020 https://research.ibm.com/blog/aifactsheets

27 “Introduction to Data-Centric AI” MIT Cambridge, MA course available online https://dcai.csail.mit.edu/

28 “What are Large Language Model Operations (LLMOps)?” IBM online enablement material (2024) https://www.ibm.com/topics/llmops

29 “What is Prompt Engineering?” IBM online enablement material (2024) https://www.ibm.com/topics/prompt-engineering

30 Langchain https://www.langchain.com/

31 LlamaIndex https://www.llamaindex.ai/